

Day 8 - Detection Engineering Philosophy & MITRE ATT&CK

Name: Mohammed Farhan

Role: Associate – Information Security (Intern)

Organization: CyberShelter UAE

Date: 7 July 2026

Objective

To move beyond isolated detection references from Week 1 and build a formal understanding of MITRE ATT&CK's structure, then produce a strategic artifact — a colored coverage map in ATT&CK Navigator — showing which attacker techniques the current lab environment can and cannot detect, backed by a written gap analysis.

PART 1 — Concepts Studied

MITRE ATT&CK's Three-Level Structure

Tactic (the WHY) — the attacker's objective at that moment. ATT&CK has 14 tactics total, each with an ID like TA0001. Think of tactics as chapter titles in an attacker's playbook.

Technique (the HOW) — the actual method used to achieve that tactic's goal. This is the level most cheat sheets reference (e.g., T1110 Brute Force). Multiple techniques can achieve the same tactic — there's rarely just one way in.

Sub-technique (the specific variant) — the most granular, actionable level, written as T1110.001. This is usually where actual detection logic gets written.

Why sub-technique matters practically: Password Guessing shows as many failed logins against ONE account from one source — this is exactly what the Day 7 custom rule (5 failures in 60 sec, same IP) catches. Password Spraying shows as few failed logins against MANY DIFFERENT accounts, spread out over time. These look completely different in logs and the Day 7 rule would completely miss a password spray — a genuine, concrete gap identified by understanding this distinction properly.

6 Priority Tactics for a SOC Engineer

Tactic	ID	Why It's a Priority
Initial Access	TA0001	"I need to get in"
Execution	TA0002	"I need to run my code"
Persistence	TA0003	"I need to survive a reboot"
Credential Access	TA0006	"I need passwords/hashes"
Lateral Movement	TA0008	"I need to reach other machines"
Exfiltration	TA0010	"I need to steal the data out"

Reasoning: These represent natural chokepoints an attacker must pass through to cause real damage. Strong detection at even 3-4 of these dramatically increases the odds of catching an intrusion somewhere along the chain, even if the very first step (e.g., initial access) is missed. This is why SOCs prioritize these over earlier ATT&CK tactics like Resource Development, which mostly happens on attacker-owned infrastructure, outside organizational visibility.

Detection Engineering Maturity Model (DML) — 5 Stages

1. **IOC (Indicators of Compromise)** — matching known-bad artifacts like specific IPs or file hashes. Weakest level — attackers change these trivially (new IP, repacked malware = different hash).
2. **Atomic Indicators** — single, very specific artifacts (a particular registry key, a particular filename).
3. **Tool-based** — detecting signatures of known attacker tools (e.g., recognizing Mimikatz's specific behavior patterns).
4. **TTP/Behavior-based** — detecting the underlying Tactics, Techniques, and Procedures themselves, regardless of which specific tool implements them. This is the level ATT&CK-based detection (this week's focus) operates at.
5. **Analytics/Anomaly-based** — detecting deviations from an established behavioral baseline (e.g., "this user never logs in at 3am, why are they now?"). Most mature, hardest to build, hardest for attackers to evade.

Key insight: Higher stages are progressively harder for attackers to evade because they target fundamentals (goals, behavior patterns) rather than superficial details (a specific IP, a specific tool) that are trivial to change.

MITRE CTID — Threat-Informed Defense

A purple-team concept from MITRE's Center for Threat-Informed Defense. The idea: detection engineering, red-team testing, and overall defense strategy should all be built directly around real, documented adversary behavior (sourced from ATT&CK) — rather than generic industry best practices that may not reflect actual threats relevant to your organization.

Palantir Alerting and Detection Strategy (ADS) Framework

A public framework (GitHub) defining the professional structure for documenting a single detection. A properly documented detection under this framework includes:

- **The technique it maps to** (which ATT&CK ID)
- **Expected false-positive rate** (how noisy is this rule expected to be)
- **Required data source** (what log/telemetry does this rule depend on)
- **Validation method** (how do you prove this rule actually works — this is exactly what Atomic Red Team, coming later this week, provides)

PART 2 — Hands-On Task: ATT&CK Navigator Coverage Layer

Tool Used

ATT&CK Navigator (<https://mitre-attack.github.io/attack-navigator/>) — a free web tool displaying the full ATT&CK matrix as a grid (tactics as columns, techniques as rows). Individual technique cells can be selected and color-coded, then the whole grid can be exported/saved as a JSON "layer" file.

Navigator Workflow (How the Tool Actually Works)

1. Search box (top) — type a technique ID (e.g., T1110), press Enter to filter/highlight it in the grid
2. Click directly on the technique's box in the matrix itself — this selects it (shows a highlighted border)
3. Click a color swatch from the toolbar — applies that color to the selected cell(s) immediately, no separate "confirm/add" step needed
4. Repeat search → click → color for each technique
5. Layer Controls icon → Export → Download as JSON to save

Color System Used

- **Blue** — I have a log that could theoretically show this, but no alert exists
- **Green** — I have a working, tested detection/alert for this (verified via wazuh-logtest, live Splunk/Kibana search results, etc.)
- **Red** — Zero visibility — no relevant log source at all

File: day8-attack-navigator-layer.json

Submission: Uploaded to Git repo under Week2/Day8/

Final Coverage Built (13 techniques colored, sourced from real Week 1 work)

Status	Technique	Name	Evidence / Reason
● Green	T1110 / T1110.001	Brute Force / Password Guessing	Day 3 Wazuh rule 5760; Day 7 custom rule 100100/100101, verified via wazuh-logtest
● Green	T1136	Create Account	Day 5 Splunk SPL (EventID 4720)
● Green	T1098	Account Manipulation	Day 6 KQL (EventCode 4732), confirmed live in Kibana
● Green	T1078	Valid Accounts	Day 5 SPL (accepted password); Day 6 KQL (logon outside business hours)
● Green	T1059.001	PowerShell	Day 6 KQL, confirmed live PowerShell execution
● Green	T1071.004	DNS (Application Layer C2)	Day 6 Sysmon Event 22
● Blue	T1003	OS Credential Dumping	Sysmon Event 1 flowing; no rule written
● Blue	T1021.004	Remote Services: SSH	SSH data exists; no dedicated lateral-movement rule
● Blue	T1018	Remote System Discovery	Firewall/nginx logs exist; no discovery rule
● Red	T1055	Process Injection	Sysmon not configured for injection-relevant events
● Red	T1090	Proxy	No network traffic/proxy inspection deployed
● Red	T1041	Exfiltration Over C2 Channel	No outbound data-volume monitoring
● Red	T1531	Account Access Removal	No monitoring for account deletion/disablement

Deliverable 2 — Detection Gap Analysis

Top 5 Undetectable Techniques

1. T1041 — Exfiltration Over C2 Channel

Why undetectable: No monitoring tracks outbound data volume or byte counts.

Fix: NetFlow, or firewall logs with byte-count fields.

2. T1055 — Process Injection

Why undetectable: Sysmon only covers Events 1, 3, 5, 22 — not injection activity.

Fix: Sysmon Event ID 7 (image load) and 8 (remote thread creation).

3. T1090 — Proxy

Why undetectable: No network traffic or proxy inspection tool deployed.

Fix: Proxy/web-gateway logs, or Zeek/Suricata.

4. T1531 — Account Access Removal

Why undetectable: No log source monitors account deletion/disablement.

Fix: Windows Event ID 4726 (deleted) / 4725 (disabled).

5. T1548 — Abuse Elevation Control Mechanism

Why undetectable: No UAC or integrity-level monitoring configured.

Fix: Windows Event ID 4672/4688 with integrity-level fields.

Conclusion

The environment shows strong detection coverage for identity and account-based techniques — brute force, account creation, account manipulation, and valid account abuse — but has no visibility into data exfiltration volume, process-level injection behavior, or proxy/C2 network traffic. Closing these gaps requires enabling additional Sysmon event IDs and deploying network-layer traffic inspection.